IDENTITY-AUTHENTICATION-NHI

# 식별·인증·비인간 신원 NHI

연관 기출 · 128-4-6, 140-1-11

## 한눈에 이해

누구라고 주장하는지와 그 주장을 어떻게 입증하는지, 어떤 권한을 언제 회수할지를 사람과 소프트웨어 모두에 적용합니다.

## 정의와 핵심 원리

식별은 계정이나 식별자로 어떤 주체인지 구분하는 절차입니다. 인증은 주체가 제시한 인증 수단을 검증하는 절차입니다. 비인간 신원(NHI)은 서비스·애플리케이션·장치처럼 사람이 아닌 주체에 부여한 신원으로, 워크로드와 장치의 신원이 여기에 포함될 수 있습니다.

• 비밀번호처럼 아는 것, 보안 키나 토큰처럼 가진 것, 생체 특성처럼 사람에게 고유한 것은 서로 다른 인증 요소입니다. 위치·행동은 위험 신호로 쓸 수 있지만 이를 독립된 요소로 분류하는지는 문헌마다 다릅니다. 같은 종류의 비밀을 두 개 써도 다중 요소 인증(MFA)은 아닙니다.

• 인증을 설계할 때는 도청·재전송·피싱·온라인 추측을 막고, 인증 수단의 등록·변경·복구·폐기 과정과 로그인 후 세션 및 접근 권한도 보호합니다. 생체 정보는 판정 오류가 발생할 수 있고, 유출 후 비밀번호처럼 쉽게 바꾸기 어렵습니다.

• 비인간 주체는 API 키·인증서·서비스 계정·관리형 신원 등으로 자원에 접근합니다. 소유자가 불분명하거나 오래 쓰는 비밀이 많고, 권한이 과도하거나 CI 로그에 자격 증명이 노출되면 위험합니다. 신원 목록과 책임자를 지정하고, 수명이 짧은 토큰·워크로드 연합·최소 권한을 적용합니다. 자격 증명의 사용을 감시하고 갱신·폐기를 관리합니다.

## 구조·비교·판단

| 구분 | 핵심 원리 | 적용·한계 |
|---|---|---|
| 사람의 신원 | 직원·고객·사용자 | MFA, 접속 맥락 확인, 퇴사 시 권한 회수 |
| 워크로드 신원 | 앱·배치·컨테이너 | 토큰·역할·실행 환경 검증 |
| 장치 신원 | 서버·IoT·단말 | 인증서·보안 상태·등록 및 폐기 |

## 적용 예제

### CI 파이프라인 자격증명

강사 생성 학습 예제입니다. 공식 기준답안이 아닙니다.

**조건:** 배포 작업에서 운영 환경에 접근해야 합니다.

1. 저장소에 장기 관리자 키를 두는 대신, 신뢰 조건을 충족한 배포 작업에 수명이 짧은 토큰을 발급합니다.
2. 대상 환경과 브랜치 등 신뢰 조건을 검증합니다.
3. 배포에 필요한 권한만 부여하고 세션·변경을 기록합니다.
4. 프로젝트 종료 시 신원·연합 관계·권한을 회수합니다.

**결과·해석:** 배포 작업이 자격 증명을 발급받는 순간부터 접근 권한을 회수할 때까지 담당자와 사용 이력을 확인할 수 있습니다.

**전제·주의:** 비밀번호 정책·보안 등급은 적용 표준과 업무 요건별 확인이 필요합니다.

## 답안 골격과 혼동 방지

식별·인증·인가 → 인증 요소 비교 → 등록부터 폐기까지의 보안 요구 → NHI 취약점 → 워크로드 예시

- API 키를 사용자 비밀번호보다 덜 민감하게 보지 않습니다.
- 생체 정보는 정확도에 한계가 있고 유출 후 교체하기 어렵습니다.

## 내용을 가리고 회상

1. 식별자와 인증 비밀의 차이는 무엇입니까?
2. NHI의 소유자를 정해야 하는 이유는 무엇입니까?
3. 비밀번호와 PIN을 함께 사용해도 왜 MFA에 해당하지 않습니까?

## 적용 기준과 근거

NIST800-63B-4(2025-07), Microsoft신원공식 문서.기출의4가 지유형분류원출처미확인;위치·행동을 독립NIST요소로사칭하지 않음.

**내용 검토 상태: 부분 확인**. 출처 확인은 공식 정답이나 학습 성취를 뜻하지 않습니다.

출처별 상세 열람 범위는 위키의 출처 기록에서 확인합니다.


- NIST SP800-63B-4 Authentication - NIST; 2025-07; 확인 2026-11-05.
- Workload identities overview - Microsoft; 상시 문서; 확인 2026-11-05.